

ZeroShield Security S.A.

Soluciones de Ciberseguridad Zero Trust

CASO DE ESTUDIO

Implementación de Red Wi-Fi Zero Trust para Empresa de Servicios Financieros

Grupo de Trabajo

Itmar Castillo 8-1027-180

Gilberto Aguilar 8-1019-2127

José Moreno 8-1019-2359

Yair Rodríguez 8-1023-2490

Curso: Ciberseguridad III

Fecha: 2026

Resumen

Este trabajo lo desarrollamos como grupo para la asignatura de Seguridad de Ciberseguridad, tomando como base un escenario de una empresa financiera con 500 empleados que necesitaba modernizar su red Wi-Fi. El problema central era que la red no diferenciaba entre dispositivos confiables y no confiables; cualquier equipo que se conectara tenía acceso a prácticamente todo, lo cual es un riesgo grave en un entorno financiero. Si un solo dispositivo se comprometía, el atacante podía moverse lateralmente sin mayores obstáculos.

Para atender eso, formamos una empresa ficticia de ciberseguridad llamada ZeroShield Security S.A. y trabajamos una propuesta técnica bajo el modelo Zero Trust. El documento cubre tres entregables principales: la identidad de la empresa, el análisis del ciclo de vida de la superficie de ataque y un prototipo de solución que mezcla autenticación 802.1X, control de acceso a la red (NAC), segmentación por VLANs y monitoreo mediante SIEM.

Palabras clave: *Zero Trust, Wi-Fi corporativo, BYOD, segmentación de red, NAC, 802.1X, superficie de ataque, seguridad financiera, trabajo híbrido.*

1. ZeroShield Security S.A.: La Empresa de Ciberseguridad

ZeroShield Security S.A. es la empresa que nuestro grupo creó para este proyecto. La ubicamos en Ciudad de Panamá, fundada en 2019, enfocada desde el principio en ciberseguridad para el sector corporativo de la región. La razón por la que escogimos el nombre tiene que ver con el concepto central de la solución: protección total basada en confianza cero, sin asumir que nada dentro de la red es seguro por defecto.

Para darle credibilidad a la empresa, la diseñamos con un equipo de alrededor de 85 profesionales, con certificaciones como CISSP, CEH y CCIE Security, operando en seis países: Panamá, Costa Rica, Colombia, Perú, México y República Dominicana. Nos pareció importante que fuera una empresa con presencia regional porque el caso de estudio refleja una problemática común en Latinoamérica.

1.1. Visión y Misión

Visión

Ser para 2030 la empresa de referencia en seguridad Zero Trust en la región latinoamericana, ayudando a las organizaciones a proteger sus operaciones digitales sin que eso le complique la vida al usuario final.

Misión

Ofrecer soluciones de seguridad que realmente reduzcan el riesgo de nuestros clientes, sin perder de vista que la seguridad tiene que ser compatible con el día a día del negocio. Aplicamos el principio de confianza cero no como una moda, sino porque funciona.

Definimos también cuatro valores que la empresa sigue en su operación diaria: integridad técnica, enfoque en el riesgo real, transparencia con el cliente y mejora continua. La idea fue que estos valores no fueran algo decorativo en un folleto, sino que se reflejaran en cómo ZeroShield trabaja con sus clientes. Por ejemplo, el valor de transparencia aplica directamente cuando se le entrega al cliente el informe de superficie de ataque, sin ocultar los hallazgos incómodos.

1.2. Estructura Organizacional de Tecnología

Para la estructura organizacional decidimos separar bien las áreas técnicas. Algo que nos pareció importante al diseñarla es que muchas empresas de seguridad tienen sus equipos solo orientados hacia afuera, es decir, trabajando para clientes pero descuidando sus propios procesos internos. En ZeroShield quisimos que eso no pasara, así que el área de I+D también trabaja mejorando las herramientas y metodologías internas.

CEO / Dirección General	Chief Information Security Officer (CISO)	Chief Technology Officer (CTO)	Director de Operaciones
Ingeniería de Soluciones	Red Team & Pentesting	Blue Team / SOC 24/7	I+D y Arquitectura
Especialistas en ZTNA	Analistas de Amenazas	Ingenieros de SIEM	Arquitectos de Red
Consultores IAM/PAM	Ingenieros de Wireless	Analistas de UEBA	Desarrolladores de Herramientas

El CISO tiene bajo su responsabilidad tanto el Red Team como el Blue Team. Esto es intencional: que el equipo que ataca y el que defiende estén coordinados hace que los hallazgos de las pruebas de penetración se conviertan rápido en mejoras reales. El CTO, por su lado, trabaja de la mano con I+D para que la empresa adopte tecnologías nuevas antes de que esas mismas tecnologías se conviertan en un vector de ataque que algún cliente deba enfrentar sin estar preparado.

1.3. Servicios que Brinda la Empresa

En cuanto a los servicios, definimos seis áreas principales. La idea fue que cubrieran todo el ciclo: desde que se evalúa qué tan expuesta está una organización, hasta que se monitorea el entorno de forma continua una vez que ya están los controles implementados.

Servicio	Descripción	Mercado Objetivo
ZeroTrust Network Access (ZTNA)	Implementación de arquitecturas de confianza cero para acceso a redes corporativas	Empresas +200 empleados
Gestión de Identidades y Accesos (IAM)	Despliegue y administración de soluciones PAM/IAM con MFA adaptativo	Sector financiero y salud
Wireless Security Assessment	Auditoría técnica de redes Wi-Fi, detección de rogue APs y análisis de protocolos	Cualquier vertical
BYOD Security Management	Políticas, MDM y controles para dispositivos personales en redes corporativas	Empresas con trabajo híbrido
SOC como Servicio (SOC-as-a-Service)	Monitoreo 24/7, correlación de eventos, respuesta a incidentes y threat hunting	Medianas y grandes empresas
Consultoría en Cumplimiento Normativo	Acompañamiento para ISO 27001, NIST CSF, PCI-DSS y regulaciones locales	Sector regulado

Estos servicios se pueden contratar por separado o combinados. Para clientes del sector financiero, que es el caso que estamos trabajando, lo más común sería combinar el ZTNA con el SOC como Servicio y la consultoría de cumplimiento normativo, porque en ese sector se tienen las dos presiones al mismo tiempo: cumplir regulaciones y defenderse de ataques cada vez más dirigidos.

1.4. Proyectos que Maneja

Para mostrar que la empresa tiene experiencia real, armamos un portafolio de proyectos. Algunos ya están terminados y otros están activos. El caso de este trabajo es el proyecto ZeroWiFi 500, que aparece como en ejecución.

Proyecto	Alcance	Duración	Estado	Cliente
ZeroWiFi 500	Implementación Zero Trust Wi-Fi para 500 empleados (caso actual)	6 meses	En Ejecución	Financiera Confidencial S.A.
SecureHybrid Pro	Plataforma de acceso seguro para trabajo remoto e híbrido con ZTNA + SASE	8 meses	Planeación	Holding Regional
IdentityCore v2	Modernización de IAM/PAM con integración SAML, OIDC y autenticación sin contraseña	5 meses	Completado	Hospital Nacional
WifiAudit Gov	Auditoría de seguridad inalámbrica y remediación para red gubernamental	3 meses	Completado	Entidad Pública
ComplianceMap 27K	Hoja de ruta hacia certificación ISO 27001 con gestión de riesgos integrada	12 meses	En Ejecución	Aseguradora Regional

ZeroWiFi 500 es el más complejo del portafolio en este momento. No es solo porque tenga 500 usuarios, sino porque hay que resolver varias cosas al mismo tiempo: permitir BYOD, eliminar la VPN tradicional, cumplir con regulaciones del sector financiero y hacerlo todo bajo un esquema Zero Trust que no afecte la experiencia de los empleados. Ese balance entre seguridad y usabilidad fue uno de los puntos más difíciles de trabajar en el diseño.

2. Análisis del Ciclo de Vida de la Superficie de Ataque

Una cosa que aprendimos al trabajar esta sección es que la superficie de ataque no es fija. Cambia cada vez que se conecta un dispositivo nuevo, cada vez que se abre un servicio o cada vez que un empleado empieza a trabajar desde casa. Por eso lo más útil no es hacer un análisis de una sola vez, sino tener un ciclo que se repita y actualice con el tiempo. Eso es básicamente lo que propone ZeroShield con este modelo.

2.1. El Problema: Superficie de Ataque en la Empresa Financiera

Al revisar el caso, identificamos varias condiciones que hacían que la empresa estuviera más expuesta de lo necesario. Vale decir que ninguna de estas cosas es rara de encontrar; de hecho es bastante común en empresas que no han actualizado su infraestructura de seguridad en varios años:

- Red Wi-Fi plana: todos los dispositivos conectados convivían en el mismo segmento de red sin diferenciación de confianza.
- Registro abierto de dispositivos: cualquier equipo aprobado por el administrador tenía acceso irrestricto, sin verificación de postura de seguridad.
- Ausencia de autenticación basada en identidad: las credenciales de red Wi-Fi eran compartidas o basadas en MAC address, fácilmente suplantables.
- VPN perimetral como único control de acceso remoto: una vez dentro del perímetro VPN, el usuario tenía acceso lateral a múltiples sistemas.
- Sin segmentación de dispositivos de invitados: visitantes y proveedores accedían al mismo entorno que servidores de aplicaciones financieras.

2.2. Ciclo de Vida: Fases y Metodología

El ciclo que diseñamos tiene siete fases. Lo alineamos con el NIST Cybersecurity Framework y el CIS Controls v8, que son los marcos de referencia que vimos en clase y que más se usan en la práctica a nivel empresarial:

Fase	Nombre	Actividades Clave	Entregables
1	Identificación	Inventario de activos, mapeo de flujos de datos, enumeración de vectores de entrada (Wi-Fi, BYOD, portales)	Mapa de superficie de ataque inicial
2	Clasificación	Categorización por criticidad (datos financieros, PII, sistemas de control), tipo de activo y exposición	Matriz de clasificación de activos
3	Análisis de Riesgo	Evaluación de probabilidad e impacto, construcción de matriz de riesgo, identificación de escenarios de amenaza	Matriz de riesgo cuantificada
4	Priorización	Ranking de vulnerabilidades por score CVSS, definición de ventanas de remediación y propietarios de riesgo	Backlog de remediación priorizado
5	Mitigación	Implementación de controles Zero Trust, segmentación de red, MFA, NAC, políticas de acceso condicional	Controles implementados y documentados
6	Monitoreo	Revisión continua con SIEM, alertas automáticas, análisis de comportamiento (UEBA), threat hunting	Dashboard de visibilidad en tiempo real
7	Retrospectiva	Revisión trimestral de la superficie, lecciones aprendidas, ajuste de políticas y repetición del ciclo	Informe de mejora continua

Lo que más nos gustó de este enfoque es que no termina. La fase de Retrospectiva no es solo para cerrar el ciclo, sino para volver a empezar desde Identificación con lo que se aprendió. Así cualquier cambio en la red, un dispositivo nuevo, un servicio que se abre al exterior, un empleado que cambia de rol, queda dentro del radar en la próxima vuelta del ciclo.

2.3. Matriz de Riesgo Identificada

Después de analizar el entorno de la empresa, levantamos esta matriz de riesgo. Los niveles los asignamos según la probabilidad de que ocurra el ataque y el impacto que tendría si llegara a materializarse:

Amenaza / Vector	Probabilidad	Impacto	Nivel de Riesgo	Prioridad
Acceso no autorizado via BYOD	Alta	Crítico	CRÍTICO	1
Movimiento lateral post-compromiso	Alta	Alto	ALTO	2
Suplantación en red de invitados	Media	Alto	ALTO	3
Interceptación de tráfico Wi-Fi	Media	Medio	MEDIO	4
Ataques de rogue AP	Baja	Alto	MEDIO	5
Exfiltración de datos financieros	Media	Crítico	CRÍTICO	1

Los dos riesgos marcados como CRÍTICO fueron los que más influyeron en el diseño de la solución. Si se mira bien, los dos tienen la misma raíz: no hay forma de saber con certeza quién se está conectando ni desde qué dispositivo, y una vez conectado, ese dispositivo puede alcanzar prácticamente cualquier parte de la red.

2.4. Reducción de Superficie: Métricas Objetivo

Para medir si la solución realmente funciona, definimos estas métricas. Son objetivos concretos que la empresa debería poder verificar una vez implementada la arquitectura:

- Reducción del 90% en los dispositivos con acceso lateral a sistemas críticos (de 500 a menos de 50 dispositivos específicamente autorizados).
- Tiempo de detección de dispositivos no autorizados: de más de 72 horas (sin visibilidad) a menos de 3 minutos con alertas automáticas.
- Eliminación del 100% de los accesos basados en MAC address o contraseñas compartidas de Wi-Fi.
- Cobertura de monitoreo continuo del 100% del tráfico inalámbrico con retención de logs de 90 días.
- Reducción del radio de compromiso potencial: de toda la red (en caso de un endpoint infectado) a un único segmento de VLAN aislado.

3. Prototipo de la Solución: ZeroWiFi 500

3.1. Principios de Diseño

Todo el diseño de la solución parte de tres principios del modelo Zero Trust. No los inventamos nosotros, vienen del framework original de Kindervag y del NIST SP 800-207, pero los adaptamos al contexto específico de este caso:

1. Nunca confiar, siempre verificar: ningún dispositivo ni usuario recibe acceso por el simple hecho de estar físicamente en la red o contar con credenciales válidas aisladas. Cada sesión se autentica de forma continua.
2. Mínimo privilegio: cada usuario y dispositivo accede únicamente a los recursos estrictamente necesarios para su función, nada más.
3. Asumir compromiso: el diseño presupone que uno o más endpoints pueden estar comprometidos en cualquier momento, por lo que los controles de segmentación limitan el daño potencial de forma proactiva.

3.2. Arquitectura de la Solución

La arquitectura funciona como una serie de filtros. Antes de que un dispositivo llegue a cualquier recurso de la empresa, tiene que pasar por varias verificaciones. Si falla alguna, no entra, o entra a un segmento muy limitado. El flujo sería así:

Flujo de acceso:

- El dispositivo se conecta al AP en modo WPA3-Enterprise.
- El AP redirige la autenticación al servidor RADIUS via EAP-TLS o PEAP.
- El RADIUS consulta el directorio de identidades (AD/LDAP) y verifica el MFA del usuario.
- El resultado de la autenticación, junto con la postura del dispositivo, llega al motor de políticas NAC.
- El NAC asigna dinámicamente una VLAN según la identidad y el estado del equipo.
- El dispositivo queda en su micro-segmento y solo accede a los recursos que le corresponden.
- Todo el tráfico pasa por el SIEM y el IDS inalámbrico para monitoreo continuo.

3.3. Stack de Controles de Seguridad

Cada capa de control tiene una tecnología específica y un propósito concreto. La tabla siguiente resume cómo se organiza todo el stack de seguridad de la solución:

Capa de Control	Tecnología / Mecanismo	Función en la Solución
Identidad y Autenticación	802.1X / RADIUS / EAP-TLS + MFA	Valida la identidad del dispositivo y del usuario antes de conceder acceso a cualquier segmento
Control de Acceso a Red	NAC (Network Access Control) / Política basada en postura	Verifica el cumplimiento del dispositivo (parches, AV, MDM) en tiempo real
Segmentación de Red	VLANs dinámicas + Micro-segmentación	Aísla empleados, invitados, IoT y servidores críticos; previene movimiento lateral
Cifrado de Tráfico	WPA3-Enterprise / TLS 1.3 end-to-end	Protege la confidencialidad de los datos en tránsito dentro y fuera de la red Wi-Fi
Visibilidad y Detección	SIEM (Splunk/ELK) + UEBA + IDS/IPS inalámbrico	Correlaciona eventos, detecta anomalías de comportamiento y bloquea amenazas en tiempo real
Gestión de Políticas	Motor de políticas Zero Trust centralizado (PDP/PEP)	Aplica el principio de mínimo privilegio de forma dinámica según contexto del usuario/dispositivo
Gestión de Endpoints BYOD	MDM / MAM + Contenedores corporativos	Separa el entorno corporativo del personal en dispositivos BYOD sin violar privacidad

3.4. Segmentación de Red: Diseño de VLANs

Uno de los puntos que más discutimos en el grupo fue cómo segmentar la red. Al final llegamos a seis VLANs, cada una con un nivel de acceso diferente dependiendo de quién se conecta y desde qué dispositivo. El motor de políticas las asigna automáticamente, así que el usuario no tiene que hacer nada especial:

VLAN / Segmento	Descripción y Política de Acceso
VLAN 10 — Empleados Corporativos	Dispositivos gestionados, autenticados vía 802.1X con certificado + MFA. Acceso a aplicaciones financieras internas. Restricción total de acceso lateral a VLAN de servidores sin autorización explícita.
VLAN 20 — BYOD Autenticado	Dispositivos personales registrados en MDM, autenticados via 802.1X + MFA. Acceso a aplicaciones en la nube (SaaS) y correo corporativo mediante contenedor seguro. Sin acceso a servidores internos.
VLAN 30 — Invitados / Visitantes	Portal cautivo con autenticación básica. Acceso únicamente a Internet con filtrado de contenido. Aislamiento total del resto de la red. Sesiones con expiración automática de 4 horas.
VLAN 40 — IoT y Dispositivos de Infraestructura	Impresoras, cámaras y sistemas HVAC. Sin acceso a Internet ni a otras VLANs. Comunicación permitida solo con sistemas de gestión específicos mediante reglas estáticas.
VLAN 50 — Servidores Críticos (No Wi-Fi)	Segmento exclusivo para servidores financieros y de bases de datos. Solo accesible desde VLAN 10 con autenticación adicional a nivel de aplicación (PAM). Monitoreo de sesiones privilegiadas activado.
VLAN 99 — Cuarentena	Destino automático para dispositivos que no superan la verificación de postura (sin parches críticos, AV desactualizado). Acceso solo a portal de remediación. Reasignación automática al superar la verificación.

3.5. Plan de Implementación por Fases

La implementación la dividimos en cuatro fases distribuidas en seis meses. Lo hicimos así porque hacer todo de una sola vez en una empresa que está operando es bastante riesgoso; es mejor ir por partes y verificar que cada etapa funcione antes de pasar a la siguiente:

4. Fase 1 — Fundamentos de Identidad (Semanas 1-4): Despliegue del servidor RADIUS, integración con Active Directory, configuración de entidad certificadora interna (PKI) y emisión de certificados de dispositivo para equipos corporativos existentes.
5. Fase 2 — Infraestructura de Red (Semanas 5-10): Reconfiguración de access points a modo WPA3-Enterprise, implementación de VLANs dinámicas en switches de distribución, despliegue del motor de políticas NAC y pruebas de conectividad por segmento.
6. Fase 3 — BYOD y Visibilidad (Semanas 11-16): Onboarding del MDM para dispositivos personales, configuración del portal de auto-registro BYOD, integración del SIEM con fuentes de log (RADIUS, firewall, APs, endpoints) y configuración de reglas de correlación y alertas.
7. Fase 4 — Operación y Ajuste (Semanas 17-24): Monitoreo activo de la red bajo la nueva arquitectura, ajuste fino de políticas basado en comportamiento real, capacitación a usuarios y administradores, y entrega del informe final de reducción de superficie de ataque.

3.6. Consideraciones de Continuidad y Resiliencia

Algo que no queríamos dejar sin resolver es qué pasa si falla algún componente. Si el servidor RADIUS cae, no se puede dejar a todos los empleados sin red. Por eso la solución incluye dos servidores en configuración activo-pasivo: si uno falla, el otro toma el relevo automáticamente.

Los certificados de dispositivo se renuevan solos cada 12 meses, sin que el administrador tenga que intervenir. Y si el servidor de identidades llega a estar caído temporalmente, el NAC puede entrar en un modo reducido que permite a los dispositivos corporativos que ya estaban autenticados seguir trabajando. No es ideal desde el punto de vista de seguridad, pero es mejor que dejar la empresa paralizada.

4. Conclusiones

Trabajar este caso nos dejó varias conclusiones útiles. La más importante quizás es que el problema de seguridad de la empresa no venía de afuera, sino de adentro: la red estaba diseñada para confiar en todo lo que se conectara, y eso es exactamente lo contrario de lo que debería ser en un entorno financiero.

Cuando analizamos la superficie de ataque, nos dimos cuenta de que si un solo dispositivo con malware se conectaba a esa red Wi-Fi, el atacante básicamente tenía acceso libre. No había nada que lo detuviera. Eso es lo que el modelo Zero Trust busca cambiar: que incluso si alguien logra entrar, no pueda llegar a los sistemas críticos porque no tiene los permisos para hacerlo.

La solución que diseñamos no es perfecta, ninguna lo es, pero cubre los vectores de riesgo más graves que identificamos. Lo que más nos convence del enfoque es que no depende de que los usuarios hagan todo bien, sino de que la arquitectura en sí misma limite el daño potencial aunque alguien cometa un error o un dispositivo sea comprometido.

También entendimos que implementar Zero Trust no es solo poner tecnología. Requiere un cambio en cómo se piensa la seguridad: dejar de asumir que lo que está dentro de la red es confiable. Ese cambio de mentalidad, más que el hardware o el software, es lo que realmente protege a una organización.

Referencias

- Kindervag, J. (2010). *Build security into your network's DNA: The zero trust network architecture*. Forrester Research.
- National Institute of Standards and Technology. (2020). *Zero trust architecture* (NIST Special Publication 800-207). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-207>
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Implementing a zero trust architecture*. National Cybersecurity Center of Excellence, NIST. <https://doi.org/10.6028/NIST.SP.1800-35>
- Center for Internet Security. (2021). *CIS Controls v8*. CIS. <https://www.cisecurity.org/controls/v8>
- Wi-Fi Alliance. (2022). *WPA3 specification version 3.1*. Wi-Fi Alliance. <https://www.wi-fi.org/file/wpa3-specification>
- Patel, R., & Bhatt, D. (2022). *Enterprise wireless security: Implementation of 802.1X and EAP-TLS in BYOD environments*. Journal of Network and Computer Applications, 198, 103299. <https://doi.org/10.1016/j.jnca.2021.103299>
- Gartner. (2023). *Market guide for zero trust network access*. Gartner Research.
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection*. ISO. <https://www.iso.org/standard/27001>